

SPIN Day 1 M1

Independent Technical Audit Report

Symbiotic Public Infrastructure Network -- Google Code for Communities 2026

Auditor: ** AntigraVity AI (Gemini 2.5 Flash, AGY IDE)
Audit Date: ** 2026-09-22 | 00:49 IST
Branch: ** Ministry-Feature-and-More
HEAD Commit: ** ac289d90 ("issues Resolved")
Inspection Method: ** File reads + grep + recorded test output. No code modified. No production APIs called.

PART 1 / 4 -- Git Changes · Schemas · Tests

1.1 Repository State at Audit Time

Branch: Ministry-Feature-and-More HEAD: ac289d90 ("issues Resolved") Upstream: up to date with origin/Ministry-Feature-and-More

Tracked changes (modified, not staged):

- * modified: Decisions.md (+6 lines / -1)
- * modified: Handover.md (+17 lines / -1)

Untracked files (new -- Day 1 only):

- * backend/spin_agents/schemas.py
- * backend/test_canonical_schemas.py
- * docs/

****Conclusion:**** Day 1 M1 produced zero modifications to any pre-existing runtime file. All new deliverables are untracked (not staged, not committed). The pre-Day-1 baseline is cleanly identified as commit ac289d90.

1.2 Files Created -- Day 1 Summary

File	Lines	Purpose
backend/spin_agents/schemas.py	444	Six canonical Pydantic V2 domain schemas
backend/test_canonical_schemas.py	311	15 schema contract unit tests
docs/day1/01-repository-architecture.md	--	Verified architecture map
docs/day1/02-pipeline-trace.md	--	Full /api/pipeline/run execution trace
docs/day1/03-location-contract.md	--	Location mismatch analysis
docs/day1/04-minimum-adk-architecture	--	ADK pipeline decision + diagram
docs/day1/05-auth-api-audit.md	--	Security audit
docs/day1/06-api-contract.md	--	Canonical REST request/response contract
docs/day1/07-blocker-register.md	--	14-item blocker register
docs/day1/README.md	--	Day 1 summary

Runtime code changes: None. No existing .py file was modified. Breaking changes: None. schemas.py is additive and not imported by any runtime module.

1.3 Six Canonical Schema Classes -- Full Field Inventory

Module path: spin_agents.schemas Location: backend/spin_agents/schemas.py

Class A: Location (shared sub-model, lines 31-85)

Field	Type	Required	Default	Constraint
latitude	float or None	Optional	None	Validator: < -90 or > 90 raises ValueError
longitude	float or None	Optional	None	Validator: < -180 or > 180 raises ValueError
address	str or None	Optional	None	--
landmark	str or None	Optional	None	--
district	str or None	Optional	None	--
state	str or None	Optional	None	--
pincode	str or None	Optional	None	--
is_verified	bool	Optional	False	--

Classmethod: from_lat_long_dict(data) -- adapter reading lat/lng or latitude/longitude and pinCode (camelCase).

Key code excerpt (schemas.py:52-64):

```
@field_validator("latitude")
@classmethod
def validate_latitude(cls, v):
    if v is not None and (v < -90.0 or v > 90.0):
        raise ValueError(f"Latitude must be between -90.0 and +90.0 degrees, got {v}")
    return v
```

Class B: EvidenceItem (shared sub-model, lines 88-94)

Field	Type	Required	Default	Constraint
evidence_type	Literal["photo", "voice_note", "video"]	REQUIRED	--	--
url	str	REQUIRED	--	--
mime_type	str or None	Optional	None	--
file_size_bytes	int or None	Optional	None	--
transcript_en	str or None	Optional	None	--

Schema 1: CitizenRequest (lines 101-147)

Field	Type	Required	Default	Constraint
request_id	str	Optional	REQ-{uuid4}	--
citizen_id	str	Optional	"anonymous"	--
description	str	REQUIRED	--	min_length=5, max_length=5000; strip v
source_language	str	Optional	"hi"	--
input_source	Literal[web, whatsapp, telegram, mobile_app]	Optional	"web"	--
location	Location or None	Optional	None	--
evidence	list[EvidenceItem]	Optional	[]	--
submitted_at	datetime	Optional	now(utc)	--

Validator note: Pydantic 2.13.4 evaluates min_length=5 before field_validators. A 3-char whitespace string (" ") hits string_too_short before the custom message. Test updated to accept either.

Field	Type	Required	Default	Constraint
request_id	str	REQUIRED	--	--
original_text	str	REQUIRED	--	--
normalized_description	str	REQUIRED	--	--
detected_language	str	Optional	"hi"	--
category	str	REQUIRED	--	--
department	str	REQUIRED	--	--
issue_type	str	REQUIRED	--	--
intent	str	Optional	"report_civic_issue"	--
severity	int	REQUIRED	--	ge=1, le=10
urgency	Literal[Low,Medium,High]	Optional	"Medium"	--
confidence	float	REQUIRED	--	ge=0.0, le=1.0
severity_reason	str or None	Optional	None	--
location	Location	REQUIRED	--	Non-nullable
extracted_entities	dict[str, Any]	Optional	{}	--
evidence_verified	bool	Optional	False	--
processing_status	Literal[completed,needs_	Optional	"completed"	--
needs_human_review	bool	Optional	False	--

Schema 3: CommunityCluster (lines 225-284)

Field	Type	Required	Default	Constraint
cluster_id	str	Optional	CLUSTER-{uuid4}	--
spatial_unit	Literal[ward,pincode,disti	Optional	"ward"	--
center_location	Location	REQUIRED	--	--
request_ids	list[str]	REQUIRED	--	min_length=1
request_count	int	REQUIRED	--	ge=1; auto-reconciled by model_validator
request_density	float	REQUIRED	--	ge=0.0
density_unit	str	Optional	"complaints_per_sq_km"	--
infrastructure_categories	list[str]	REQUIRED	--	--
dominant_category	str	REQUIRED	--	--
affected_population_estimate	int or None	Optional	None	ge=0
is_red_zone	bool	Optional	False	--

Model validator: validate_cluster_counts auto-corrects request_count to len(request_ids).

Schema 4: DataContext (lines 291-337)

Field	Type	Required	Default	Constraint
cluster_id	str	REQUIRED	--	--
demographic_context	dict[str, Any]	Optional	{}	--
infrastructure_condition	str or None	Optional	None	--
infrastructure_gap	bool	Optional	False	--
current_investment_cr	float or None	Optional	None	ge=0.0 when not None
planned_investment_cr	float or None	Optional	None	ge=0.0 when not None
gati_shakti_overlap	dict[str, Any]	Optional	{}	--
source_metadata	dict[str, str]	Optional	{}	--
data_quality_score	float	Optional	1.0	ge=0.0, le=1.0

Field	Type	Required	Default	Constraint
synthetic_data_flag	bool	Optional	False	Explicit disclosure flag

Schema 5: PriorityRecommendation (lines 344-391)

Field	Type	Required	Default	Constraint
recommendation_id	str	Optional	REC-{uuid4}	--
cluster_id	str	REQUIRED	--	--
priority_score	float	REQUIRED	--	ge=0.0, le=100.0
score_components	dict[str, float]	Optional	{}	--
recommended_intervention	str	REQUIRED	--	--
reasoning	str	REQUIRED	--	--
supporting_evidence	list[str]	Optional	[]	--
limitations	list[str]	Optional	[]	--
processing_status	Literal[PROPOSED,UNDERREVIEW,ACTIONED,REJECTED]	Optional	"PROPOSED"	--
model_version	str	Optional	"gemini-2.5-flash@adk-v"	--
human_review_status	Literal[PENDING,ACCEPTED,MODIFIED,REJECTED,PENDING]	Optional	"PENDING"	--

Schema 6: PolicyAction (lines 398-444)

Field	Type	Required	Default	Constraint
action_id	str	Optional	ACT-{uuid4}	--
recommendation_id	str	REQUIRED	--	--
grievance_id	str or None	Optional	None	--
reviewer_id	str	REQUIRED	--	--
reviewer_role	str	REQUIRED	--	--
decision	Literal[approved,rejected]	REQUIRED	--	--
selected_interventions	list[str]	Optional	[]	--
allocated_budget_cr	float or None	Optional	None	ge=0.0 when not None
notes	str or None	Optional	None	--
reviewed_at	datetime	Optional	now(utc)	--

1.4 Runtime Integration Status

Verified by grep (from spin_agents.schemas):

* Only match: backend/test_canonical_schemas.py:13

CONCLUSION (VERIFIED): schemas.py is NOT imported by any runtime module -- not api.py, runner.py, agent.py, auth.py, or any tool. The schemas are contract documentation only, not yet integrated into the live API path.

1.5 Test Execution -- Verified Results

Command: python -m pytest backend/test_canonical_schemas.py -v Interpreter: C:\Users\Skmaa\AppData\Local\Python\pythoncore-3.14-64\python.exe Platform: win32 -- Python 3.14.6, pytest-9.1.1, pluggy-1.6.0 Exit code: 0

#	Test	Result
1	test_valid_citizen_request	PASSED
2	test_empty_or_blank_description_rejection	PASSED
3	test_valid_parsed_request	PASSED
4	test_invalid_confidence_bounds	PASSED

#	Test	Result
5	test_valid_latitude_and_longitude	PASSED
6	test_latitude_greater_than_90_rejected	PASSED
7	test_longitude_less_than_minus_180_rejected	PASSED
8	test_unknown_location_preserves_none	PASSED
9	test_no_automatic_zero_substitution	PASSED
10	test_community_cluster_validation	PASSED
11	test_data_context_missing_data_and_synthetic_flag	PASSED
12	test_priority_recommendation_score_validation	PASSED
13	test_policy_action_decision_validation	PASSED
14	test_schema_serialization	PASSED
15	test_existing_import_compatibility	PASSED

Result: 15 passed, 0 failed, 8 warnings -- 16.72s

Baseline endpoint tests (test_api_endpoints.py): Command: python -m pytest backend/test_api_endpoints.py -v Exit code: 1

Test	Result
test_health_endpoint	PASSED
test_citizen_webhook_text_with_locatio	PASSED
test_citizen_webhook_missing_location	PASSED
test_pipeline_run_intake_only	PASSED
test_dashboard_summary	PASSED
test_dashboard_red_zones	PASSED
test_policy_action	PASSED (unauthenticated -- SEC-02 confirmed)
test_staff_department_filtering	FAILED (404 -- route does not exist)
test_staff_grievance_authorization_check	FAILED (404 -- route does not exist)

Result: 7 passed, 2 failed, 9 warnings -- 18.43s Both failures are pre-existing baseline failures, not introduced by Day 1.

PART 2 / 4 -- API Contract & Full Pipeline Trace

2.1 /api/pipeline/run -- Route Registration

- * Source: backend/spin_agents/api.py, line 136
- * HTTP Method: POST
- * Path: /api/pipeline/run
- * Route function: pipeline_run(payload: PipelineRequest)
- * Auth: None -- no JWT dependency, no middleware

2.2 Request Model -- Actual (PipelineRequest, api.py:65-71)

```
class PipelineRequest(BaseModel):
    user_id: str = "anonymous"
    text: str # REQUIRED
    source_language: str = "hi"
    location: dict | None = None # raw dict, not validated
    media_url: str | None = None
    run_adk: bool = True
```

Field	Type	Required	Notes
user_id	str	No	Defaults "anonymous"
text	str	YES	No length validation

Field	Type	Required	Notes
source_language	str	No	Default "hi"
location	dict or None	No	Raw unvalidated dict
media_url	str or None	No	--
run_adk	bool	No	Default True

Gap vs canonical CitizenRequest: No description validation, no length limits, no location bounds, no input_source enum, no evidence list.

2.3 Actual Call Chain -- Complete Trace

```

POST /api/pipeline/run
?
??? STEP 1: Translation (api.py:139-148)
?   ??? if source_language != "en":
?   ?   ??? await bhashini_translate()
?   ?       ??? Bhashini API (if keys set)
?   ?       ??? Fallback: translate_service.py (Google Translate)
?   ?       ??? Fallback: passthrough (text unchanged)
?   ??? else: identity dict
?
??? STEP 2: Intake dict assembly (api.py:150-158)
?   ??? {original_text, english_translation, user_id,
?         media_url, location_data: payload.location,
?         source_language, hitl_required: payload.location is None}
?
??? STEP 3: Early exits (api.py:160-168)
?   ??? if not run_adk -> return {intake_payload, status:"intake_only"}
?   ??? if hitl_required -> return {status:"awaiting_location", ...}
?
??? STEP 4: run_pipeline() -> runner.py:27
?
??? ADK LIVE PATH (runner.py:38-78)
?   ??? Creates InMemorySession
?   ??? _runner.run_async() -> iterates ADK events
?   ?   ??? root_agent = local_pipeline (SequentialAgent)
?   ?       ??? chatbot_intake_agent (LlmAgent)
?   ?       ?   ??? bhashini_translate_tool -> asyncio.run() BLOCKER
?   ?       ?   ??? hitl_location_gate (deterministic Python)
?   ?       ?   ??? semantic_parsing_agent (LlmAgent)
?   ?       ?   ??? vision_analyze_tool
?   ?       ?   ??? geospatial_correlation_agent (LlmAgent)
?   ?       ?   ??? gati_shakti_query_tool -> asyncio.run() BLOCKER
?   ?       ?   ??? bigquery_insert_tool -> BigQuery write
?   ?       ?   ??? policy_dashboard_agent (LlmAgent)
?   ?       ?   ??? bigquery_summary_tool
?   ?       ?   ??? bhashini_reverse_notify_tool -> asyncio.run() BLOCKER
?   ??? except Exception -> _fallback_structured_pipeline()
?
??? FALLBACK PATH (runner.py:81-182)
?   ??? loc = intake.get("location_data") or {lat:18.5204, lng:73.8567}
?   ??? Keyword heuristic -> domain + severity (no LLM)
?   ??? parsed_payload with lat_long: {lat, lng} <- MISMATCH
?   ??? insert_grievance_record(parsed_payload) <- BigQuery (0,0) bug
?   ??? SQLite write (correct coordinates)
?   ??? Returns same response shape as live path

```

2.4 Actual Response Structure

```
{
  "status":      "completed",
  "session_id":  str,
  "pipeline_status": str,
  "intake_payload": dict or None,
  "parsed_payload": dict or None,
  "geospatial_result": dict or None,
  "policy_output": dict or None,
  "final_response": str,
}
```

No field distinguishes LIVE_AI from DEMO_FALLBACK. Both paths return identical shapes.

2.5 Actual vs. Proposed Contract Comparison

Dimension	Actual (production)	Proposed Canonical
Request model	PipelineRequest (6 fields)	CitizenRequest (8 fields, validated)
Location type	dict or None	Location with bounds validation
Description validation	None	min_length=5, max_length=5000
Response model	Untyped dict	ParsedRequest, DataContext, PriorityRecommendation
Mode disclosure	Absent	processing_mode: LIVE_AI or DEMO_FALLBACK
Lat/Lng format	lat_long: {lat, lng}	location: {latitude, longitude, ...}
Auth required	No	Optional JWT
confidence field	Absent from response	Present in ParsedRequest

2.6 Full Route Inventory

Route	Method	Auth	Notes
/health	GET	None	Status probe
/api/translate	POST	None	Google Translate passthrough
/webhook/citizen	POST	None	WhatsApp/Telegram intake
/webhook/firebase	POST	None	Firebase adapter
/api/pipeline/run	POST	NONE	Main AI pipeline
/api/dashboard/summary	GET	NONE	BigQuery aggregates
/api/dashboard/red-zones	GET	NONE	BigQuery heatmap data
/api/dashboard/policy-action	POST	NONE	CRITICAL: unauthenticated policy execution
/api/grievances	GET	NONE	All citizen records exposed
/api/auth/*	various	--	Auth router
/api/config/*	various	--	Config router

get_current_user dependency: ZERO usages in entire backend/ (verified by grep).

PART 3 / 4 -- ADK Async Blocker · Location & BigQuery

3.1 asyncio.run() -- All Occurrences (Verified by grep)

File	Line	Call
spin_agents/agent.py	64	asyncio.run(bhashini_notify_citizen(...))
spin_agents/tools/bhashini.py	166	asyncio.run(bhashini_translate(...))
spin_agents/tools/gati_shakti.py	72	asyncio.run(query_gati_shakti_layers(...))
simulate_pipeline.py	182	asyncio.run(main()) -- top-level, safe

File	Line	Call
scripts/create_admin.py	59	asyncio.run(create_admin()) -- top-level, safe

The three tool wrapper calls are the problem. The remaining two are acceptable.

3.2 The Three Problematic Calls -- Exact Code

agent.py:58-67 (bhashini_reverse_notify_tool):

```
def bhashini_reverse_notify_tool(message_en, target_language, user_id):
    import asyncio
    result = asyncio.run(          # LINE 64 -- fails inside ASGI loop
        bhashini_notify_citizen(message_en, target_language, user_id)
    )
    return json.dumps(result)
```

bhashini.py:162-167 (bhashini_translate_sync):

```
def bhashini_translate_sync(text, source_language="hi"):
    import asyncio
    result = asyncio.run(          # LINE 166 -- fails inside ASGI loop
        bhashini_translate(text, source_language, "en")
    )
    return json.dumps(result)
```

gati_shakti.py:67-73 (query_gati_shakti_sync):

```
def query_gati_shakti_sync(latitude, longitude, domain):
    import asyncio, json
    result = asyncio.run(          # LINE 72 -- fails inside ASGI loop
        query_gati_shakti_layers(latitude, longitude, domain)
    )
    return json.dumps(result)
```

3.3 Why These Calls Fail

Call path:

```
POST /api/pipeline/run (uvicorn ASGI loop running)
??? await run_pipeline()      <- async, called from ASGI
    ??? _runner.run_async() <- ADK async generator
        ??? LlmAgent calls tool: bhashini_translate_tool()
            ??? bhashini_translate_sync()
                ??? asyncio.run() <- RuntimeError raised
```

asyncio.run() creates a new event loop. Python raises: RuntimeError: This event loop is already running

The broad except Exception in runner.py:75 catches this silently and routes all execution to the deterministic fallback. The API caller never sees the error.

3.4 Can the Live LLM Path Execute?

Assessment: NO -- when called via FastAPI ASGI with tool invocation.

The Gemini LLM itself might respond, but as soon as the LLM calls any registered tool (bhashini, gati_shakti, bigquery_notify), the event loop conflict fires. The fallback catches it silently.

Caveat: If Gemini responds in one turn without calling a tool, that single step could complete. But any tool call = crash + silent fallback.

3.5 Minimal Safe Fix (Do Not Implement Now -- Audit Only)

Option A -- ThreadPoolExecutor (no new dependency):

```
def bhashini_translate_sync(text, source_language="hi"):
    import asyncio, concurrent.futures
    loop = asyncio.get_event_loop()
    if loop.is_running():
        with concurrent.futures.ThreadPoolExecutor() as pool:
            future = pool.submit(asyncio.run,
                                bhashini_translate(text, source_language, "en"))
            result = future.result(timeout=30)
    else:
        result = asyncio.run(bhashini_translate(text, source_language, "en"))
    return json.dumps(result)
```

Option B -- nest_asyncio (simplest, requires pip install nest_asyncio):

Once at top of runner.py or api.py

```
import nest_asyncio
nest_asyncio.apply() # allows asyncio.run() inside running loop
```

Team must approve approach (DQ-05) before implementation.

3.6 Location & BigQuery Mismatch -- Verified

Producer (runner.py:84-113):

```
loc = intake.get("location_data") or {"lat": 18.5204, "lng": 73.8567} # Pune default
lat = loc.get("lat", 18.5204)
lng = loc.get("lng", 73.8567)
parsed_payload = {
    ...
    "lat_lng": {"lat": lat, "lng": lng}, # nested dict
    ...
}
insert_grievance_record(parsed_payload) # passes this dict
```

Consumer (bigquery.py:47-48):

```
"latitude": float(grievance_data.get("latitude", 0.0)), # key not found -> 0.0
"longitude": float(grievance_data.get("longitude", 0.0)), # key not found -> 0.0
```

Mismatch table:

Step	Key	Value
runner.py produces	"lat_lng": {"lat": 18.52, "lng": 73.85}	nested dict
bigquery.py reads	grievance_data.get("latitude", 0.0)	not found -> 0.0
bigquery.py reads	grievance_data.get("longitude", 0.0)	not found -> 0.0
BigQuery row	latitude=0.0, longitude=0.0	NULL ISLAND

SQLite is unaffected: runner.py:148-149 writes latitude=lat, longitude=lng from local variables -- correct.

ADK live path (if it ran): agent.py:188 instructs the LLM to output lat_lng: {lat, lng} -- same mismatch would occur.

3.7 Dashboard Impact

query_red_zones (bigquery.py:122-133) groups by ROUND(latitude,3), ROUND(longitude,3). If all rows have (0.0, 0.0), ROUND(0.0, 3) = 0.0 for every row. All records cluster at {lat:0.0, lng:0.0} -- the Gulf of Guinea, not India.

Limitation -- explicitly disclosed: No BigQuery credentials were available. All mismatch findings are static code analysis. The safe read-only diagnostic for authorized review:

```
SELECT
  COUNT(*) AS total_rows,
  COUNTIF(latitude = 0.0 AND longitude = 0.0) AS null_island_rows,
  COUNTIF(latitude BETWEEN 6.0 AND 37.0
    AND longitude BETWEEN 68.0 AND 97.0) AS valid_india_rows,
  MIN(created_at) AS earliest_record,
  MAX(created_at) AS latest_record
FROM `{PROJECT_ID}.spin_grievances.citizen_complaints`
LIMIT 1;
```

Do NOT modify or delete warehouse data.

PART 4 / 4 -- Authentication Audit · Blockers · Final Verdict

4.1 JWT Configuration -- Verified

auth.py:25-26

```
JWT_SECRET = os.getenv("JWT_SECRET", "supersecretkey") # hardcoded fallback
JWT_ALGORITHM = "HS256"
```

"supersecretkey" is visible in the public repository. No startup guard exists. Any attacker with repo access can forge SPIN JWTs offline.

Token claims: sub (user ID), role, optionally dept. Expiry: 24 hours.

get_current_user dependency: ZERO usages in api.py -- no JWT guard on any route.

4.2 Authentication Issue Register

ID	Issue	Severity	File / Function	Verified Evidence	Impact	Required Fix	Day
SEC-01	Password reset	CRITICAL	auth.py:166-181	Direct hash replacement	Account takeover	Securely store and verify tokens; verify before reset	Day 1
SEC-02	/api/dashboard	CRITICAL	api.py:202-21	test_policy_a	Anyone approved	Add Dependencies	Day 2
SEC-03	Hardcoded JWT	HIGH	auth.py:25	"supersecretkey"	Offline token forgery	Base Runtime	Day 2
SEC-04	/citizen-login	HIGH	auth.py:235-24	Lines 247-26	DB poisoning	Remove /citiz	Day 2
SEC-05	GET /api/grievances	MEDIUM	api.py:234-263	No Dependencies	Citizen data exposure	Add JWT + role	Day 2
SEC-06	Dashboard sidebar	MEDIUM	api.py:177-18	No Dependencies	Policy intelligence	Add staff JWT	Day 3
WARN-01	@app.on_event("startup")	LOW	api.py:80	Confirmed in test	Warnings every	Replace with lifespan handler	Day 3
WARN-02	SequentialAgent	LOW	agent.py:327	Confirmed in	Future ADK	Plan migration	Day 4+

4.3 Duplicate Route / Symbol Collision -- Verified

auth.py contains two CitizenLoginRequest classes and two citizen_login functions:

auth.py:38-41 -- first definition

```
class CitizenLoginRequest(BaseModel):
    countryCode: str
    phone: str
    password: str

# auth.py:231-233 -- second definition (overwrites first)
class CitizenLoginRequest(BaseModel):
    identifier: str # mobile or email
    password: str

# auth.py:116 -- /citizen/login (correct: validates, rejects unknown)
@router.post("/citizen/login")
async def citizen_login(req: CitizenLoginRequest, ...): ...

# auth.py:235 -- /citizen-login (dangerous: auto-creates accounts)
@router.post("/citizen-login")
async def citizen_login(req: CitizenLoginRequest, ...):
    if not user:
        # Auto-create citizen user <- VERIFIED DANGEROUS BEHAVIOR
        user = User(email=..., phone_number=..., password_hash=...)
        db.add(user); await db.commit()
```

Both routes are callable. Frontend authService.ts correctly calls /api/auth/citizen/login. The /citizen-login orphan is accessible to any caller.

4.4 Missing /api/staff/grievances -- Live Test Verified

```
FAILED: test_staff_department_filtering
GET /api/staff/grievances -> 404 Not Found

FAILED: test_staff_grievance_authorization_check
GET /api/staff/grievances/SPIN-2026-WTR001 -> 404 Not Found
```

Route does not exist in api.py. Pre-existing baseline failure.

4.5 Password Hashing -- Confirmed Safe

auth.py:23

```
pwd_context = CryptContext(schemes=["bcrypt"], deprecated="auto")
```

bcrypt via passlib is correct. No password hash is ever returned in any API response. The vulnerability is in the reset flow (no token), not the hashing algorithm.

SECTION 6 -- Final Verdict and Handoff

6.1 Day 1 M1 Deliverable Status

Deliverable	Status
Six canonical Pydantic V2 schemas	COMPLETE -- all 6 classes + 2 sub-models
15 schema unit tests	COMPLETE -- 15/15 PASSED (live verified)
Pipeline trace documentation	COMPLETE -- 7 docs, all findings verified against source
Blocker register	COMPLETE -- 14 items with severity/owner/day
Day 1 README summary	COMPLETE

6.2 Schema Implementation Quality

YES -- correctly implemented and verified:

- * Location rejects out-of-bounds coordinates; preserves None (never defaults to 0.0)
- * CitizenRequest.description validated for length and non-whitespace
- * ParsedRequest.confidence bounded to [0.0, 1.0]
- * ParsedRequest.severity bounded to [1, 10]
- * CommunityCluster.request_count auto-reconciles to len(request_ids)
- * DataContext.synthetic_data_flag provides explicit mock data disclosure
- * PolicyAction.decision is a strict Literal enum

6.3 Runtime Integration

NO -- schemas.py is imported only by test_canonical_schemas.py. Runtime modules use their own inline Pydantic models.

6.4 Existing API Contract Documentation Accuracy

YES -- and one live-test update: test_policy_action passes without auth (SEC-02 now live-verified).

6.5 Minimum ADK Demo Pipeline

local_pipeline (SequentialAgent) with 5 stages:

- * Chatbot_Intake_Agent (LLMAgent + Bhashini)
- * HitLocationGate (deterministic Python)
- * Semantic_Parsing_Agent (LLMAgent + Gemini 2.5 Flash + Vision)
- * Geospatial_Correlation_Agent (LLMAgent + Gati Shakti + BigQuery)
- * Policy_Dashboard_Agent (LLMAgent + BigQuery + Bhashini notify)

BLOCKER: asyncio.run() in tool wrappers must be fixed before this can run.

6.6 Verified Blockers

ID	Status
B-01: Password reset -- no token/OTP	VERIFIED
B-02: policy-action unauthenticated	VERIFIED (live test)
B-03: BigQuery (0.0, 0.0) mismatch	VERIFIED (static code)
B-04: asyncio.run() inside ASGI	VERIFIED (3 call sites)
B-05: Hardcoded JWT secret	VERIFIED
B-06: Duplicate /citizen-login auto-creat	VERIFIED
B-07: Hardcoded Pune default	VERIFIED (runner.py:84)
B-08: Frontend localStorage not persist	VERIFIED (grievanceService.ts)
B-09: /api/grievances unauthenticated	VERIFIED
B-11: Missing /api/staff/grievances	VERIFIED (live test 404)

6.7 Unverified Blockers

ID	Reason
B-10: other_resolver_agent disconnected	Code confirmed, live impact needs ADK run
B-03 (warehouse data)	No BigQuery credentials to query actual rows

ID	Reason
B-04 (live ASGI crash)	Inferred from static analysis -- server not running

6.8 Files to Change First on Day 2 (Priority Order)

- * backend/spin_agents/tools/bhashini.py (line 166) -- fix asyncio.run()
- * backend/spin_agents/tools/gati_shakti.py (line 72) -- fix asyncio.run()
- * backend/spin_agents/agent.py (line 64) -- fix asyncio.run()
- * backend/spin_agents/tools/bigquery.py (lines 47-48) -- fix lat/lng adapter
- * backend/spin_agents/auth.py (lines 166-181) -- add token check to password reset
- * backend/spin_agents/api.py (line 202) -- add JWT dependency to policy_action
- * backend/spin_agents/auth.py (lines 235-283) -- remove /citizen-login
- * backend/spin_agents/api.py (new route) -- implement GET /api/staff/grievances
- * backend/spin_agents/auth.py (line 25) -- add startup guard for JWT secret

6.9 Changes Requiring Team Approval

Decision	Stakeholders
DQ-01: RaiseGrievanceForm POST to backend to fail storage	Backend M2 to Frontend Lead
DQ-02: Real Twilio OTP vs mock OTP	M1 + Project Lead
DQ-03: DEMO_FALLBACK disclosed in dashboard UI?	All Hands
DQ-04: Reconnect other_resolver_ager	M1
DQ-05: nest_asyncio vs ThreadPoolExecutor fix	M1 + Technical Lead

6.10 Existing Features That May Break

Feature	Risk	Cause
/api/auth/citizen/login	Low	After /citizen-login removal, verify no frontend uses o...
Dashboard heatmap	Currently broken	BigQuery fix will start returning real coordinates (imp...
Policy action approval	Will require login after SEC-02 fix	ApprovalPortal.tsx must send JWT header
test_policy_action baseline test	Will fail after SEC-02 fix	Currently passes because endpoint is open
SQLite grievance records	None	Stores correct coordinates already

6.11 Day 2 Implementation Checklist

```
DAY 2 BACKEND CHECKLIST
=====

[ ] 1. FIX asyncio.run() -- bhashini_translate_sync (bhashini.py:166)
    Team approve approach first (DQ-05)

[ ] 2. FIX asyncio.run() -- query_gati_shakti_sync (gati_shakti.py:72)
    Same pattern as #1

[ ] 3. FIX asyncio.run() -- bhashini_reverse_notify_tool (agent.py:64)
    Same pattern

[ ] 4. FIX BigQuery location adapter (bigquery.py:47-48)
    Read lat_long.lat / lat_long.lng if latitude key missing
    Store None instead of 0.0 for unknown coordinates
    Verify BigQuery schema allows NULL in lat/lng columns

[ ] 5. SECURE password reset (auth.py:166-181)
    Add reset_token to /forgot-password
```

Verify token before updating password_hash

- [] 6. SECURE policy-action endpoint (api.py:202)
 - Add Depends(get_current_user) + role in {"policymaker", "admin"}
 - Update ApprovalPortal.tsx to send Authorization header
- [] 7. REMOVE duplicate /citizen-login (auth.py:235-283)
 - Verify no frontend caller before deleting
 - Remove second CitizenLoginRequest class
- [] 8. ADD JWT startup guard (auth.py:25)
 - if JWT_SECRET == "supersecretkey": raise RuntimeError(...)
- [] 9. IMPLEMENT GET /api/staff/grievances (api.py -- new route)
 - With X-Staff-Department filter and JWT auth
 - Fixes 2 failing baseline tests
- [] 10. TEST ADK live path after #1-3 are fixed
 - Run: python simulate_pipeline.py
- [] 11. RUN full test suite
 - python -m pytest backend/ -v
 - Target: 9/9 test_api_endpoints.py
 - 15/15 test_canonical_schemas.py

===== END OF AUDIT REPORT =====

Auditor: Antigravity AI (Gemini 2.5 Flash, AGY IDE) Model/Version: Gemini 2.5 Flash -- September 22, 2026